SAINTCON 2026

TOTP Is No Longer Enough

Defeating MFA with Session Stealing

Brian Hoopes · Oct 28, 11:30 AM

WHO AM I

Brian Hoopes

Director of Application Security

Deseret Management Corporation

Views and opinions are my own and do not represent my employer.



GROUND RULES

Educational purposes only

Everything you'll see runs on infrastructure **I control** — a fictional company ("Tons of Phish"), my own domains, throwaway demo accounts. No real third party is targeted.

For education and defense only. Run against systems you don't own, or without explicit written authorization, these techniques are illegal. Don't.



TONS OF
PHISH

THE SETUP

They did everything right.

Strong password. MFA switched on. The account was taken over anyway.

WHY THIS, NOW

This is not rare — and it is rising

Adversary-in-the-middle kits — Evilginx, EvilProxy, Tycoon 2FA — have commoditized real-time MFA bypass and session-token theft.

45% of identified phishing techniques are now **adversary-in-the-middle** kits — the single most common method.

87.7% of phishing intrusions target credentials or session cookies.

Source: Microsoft Digital Defense Report 2026 (Jul 2025–Jun 2026)

You'll watch it happen live, three times — then watch one thing stop it.

THE MENTAL MODEL

Why we all trusted TOTP

“Even if they steal my password, they can’t get my rotating code.”

TOTP solved a real problem: static passwords that get reused, leaked, and replayed. The second factor was a genuine step up.

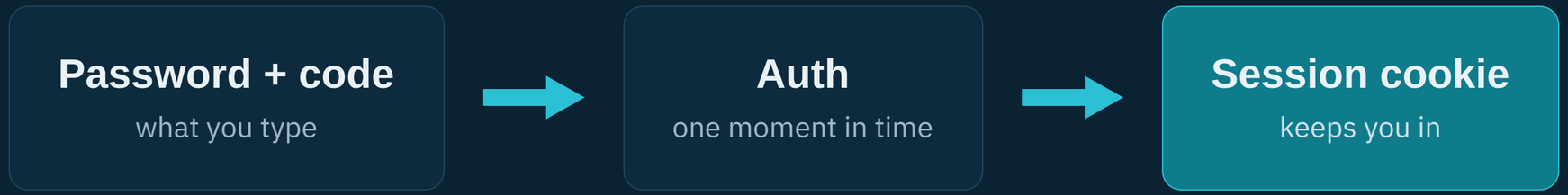
THE MENTAL MODEL

“They can’t get my rotating code.”

For years, that was a safe assumption — **today it isn’t.**

THE MENTAL MODEL

What actually keeps you logged in



The **session token** — not the password, not the code — is the keys to the kingdom.

DEMO 1 · NO MFA

Classic phishing, no MFA

What to watch:

- A lure email arrives
- Victim clicks through to a fake login
- Credentials are captured
- Attacker logs in as the victim

LIVE DEMO 1

Phishing with no MFA

demo-nomfa · tonsofphish.com

DEMO 1 · RECAP

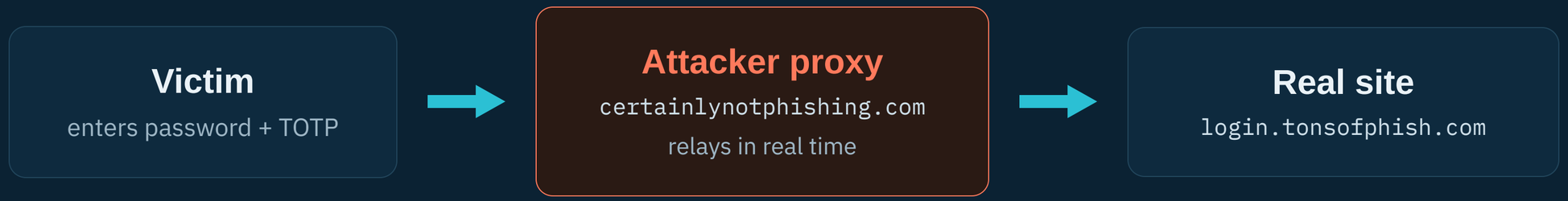
Creds alone = game over

Nothing surprising yet. This is the part everyone already knows.

Now let’s turn on MFA.

DEMO 2 · TOTP · THE CENTERPIECE

Adversary-in-the-middle



The proxy relays **everything** the victim types — including the OTP — then keeps the **session cookie** the real site hands back.

LIVE DEMO 2

TOTP, defeated by session stealing

demo-totp · tonsofphish.com

THE AHA

The TOTP was valid.

It didn’t matter.

It was never about secrecy

- An AiTM proxy relays **anything** the user types — including the one-time code.
- Infostealer malware lifts live session cookies straight out of the browser.

The flaw isn’t that TOTP codes leak. It’s that a valid login produces a bearer token anyone can carry.

THE ROOT CAUSE

Nothing binds the login to the real site — or the device.

Every factor so far trusted whoever asked for it. **The attacker just asked.**

DEMO 3 · NUMBER MATCHING

“Type the number from your phone”

Number-matching push is a genuine win against push-fatigue and MFA-bombing — you can’t blind-tap “approve” when you have to pick the right number.

But the proxy can relay a typed number just like a TOTP.

LIVE DEMO 3

Number-matching push, also relayed

demo-push · tonsofphish.com

THE PATTERN

Three postures. All relayed.

The common thread: nothing bound the login to the real site.

THE FIX

What actually stops it: origin binding

FIDO2 / WebAuthn / passkeys. The authenticator signs a challenge tied to the real domain. The private key never leaves the device and is never transmitted — so there’s no bearer secret to relay.



`login.tonsofphish.com`

Signature valid — you’re in



`certainlynotphishing.com`

Wrong origin — no valid response

DEMO 4 · PASSKEY · THE FIX

Same attack, one change

We change **nothing** about the attack — same lure, same proxy, same everything you've just watched work three times.

The only difference: this account uses a passkey.

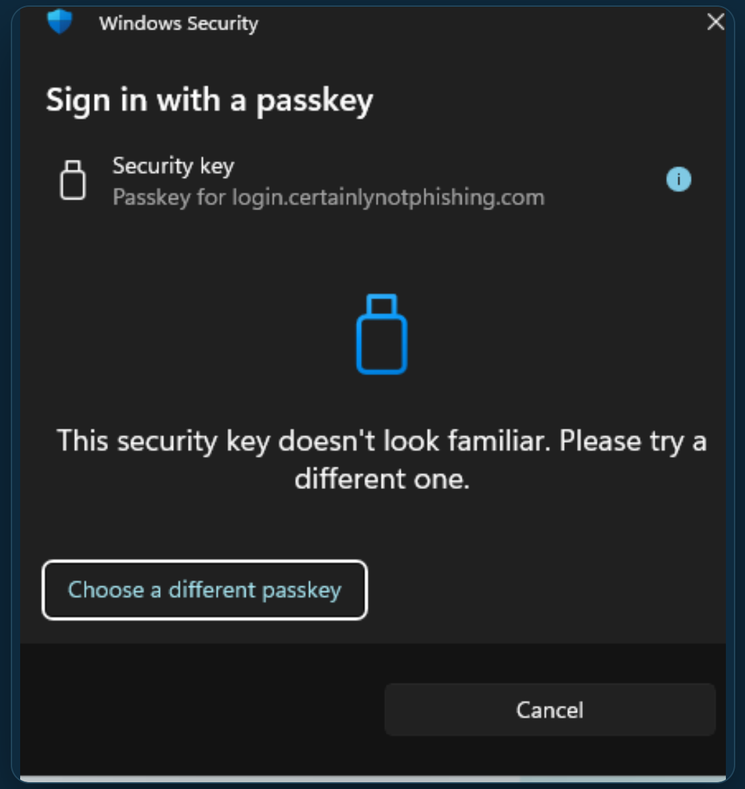
LIVE DEMO 4 — THE ATTACK FAILS

The passkey won’t play along

Same lure, same proxy — the only change is that **demo-passkey** uses a passkey.

The browser asks the key for a credential on `certainlynotphishing.com` — and your key only knows the real site. It won’t answer.

`Captured: password. Session tokens: none.`



WHY IT FAILED

The key won’t answer an impostor

Your passkey is bound to the real origin. On the attacker’s domain the browser can only ask for a credential that was never registered there — *“this security key doesn’t look familiar.”* There’s nothing to relay.

The proxy captured the password — and the session came back **empty**. Got the password. Got nothing.

HONEST CAVEAT

Passkeys fix the login — not everything

Passkeys stop the **authentication** phish. But once you're in, the session cookie is still a bearer token — an infostealer on the real device can lift it regardless of how you logged in.

Session theft is a separate problem from auth phishing.

DEFENSE IN DEPTH

Bind the session, not just the login

- **Phishing-resistant MFA** (passkeys / FIDO2) — the bar now, not the nice-to-have.
- **Device-bound sessions** (Google DBSC, Microsoft token protection) — a stolen cookie is inert on another device.
- **Conditional / risk-based access** — managed device, impossible travel, new-ASN. (In our lab, network binding would have rejected the replay — we turned it off to make the demo work.)
- **Shorter sessions + step-up reauth** for sensitive actions — shrink the window a stolen token is useful.
- **Detect anomalous session replay** (ITDR) — catch the token being used from somewhere it shouldn't be.

TAKEAWAY

Protect the session, not just the login.

Phishing-resistant MFA is the bar.

Thank you.

Questions?

brian.hoopes@gmail.com

Tons of Phish · SaintCon 2026